

****Supply Chain Chaos**** npm ecosystem hit. Multiple software supply chain attacks used malicious packages. Threat actors distributed a Rust-based information stealer and a self-spreading worm. JFrog reported this, affecting thousands of developers. Estimates suggest a 200% rise in malicious package detections.

We've seen teams assume their software supply chain is secure, but our team saw firsthand how a single compromised package can lead to a massive breach, resulting in millions of dollars in damages. The ****IronWorm**** and ****New Miasma Worm**** attacks showed that even trusted packages can be compromised, distributing malware and stealing sensitive data.

It's code review or it's breach. We worked with a client who had a malicious package discovered after review. To mitigate software supply chain risks, tools like `NO GUINPH` ****microsoft/agent-governance-toolkit**** (`NO GUINPH` 4041) provide policy enforcement, zero-trust identity, execution sandboxing, and reliability engineering. As a practitioner, I recall a case where a client's timely code review saved them from a potential breach, and another instance where a company's lack of visibility led to a devastating attack. Will